OpenSSF CRA Tech Talk

Introducing: ORBIT Launchpad

MON, FEB 23, 2026 | 10:00AM ET

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Copyright © 2024 The Linux Foundation®. All rights reserved. The Linux Foundation has registered trademarks and uses trademarks.

Agenda

- Housekeeping
- Speaker Introductions
- The origin story
- Launchpad at a glance
- Perspective: Global Cyber Policy WG
- Perspective: ORBIT WG
- Opportunities and Emerging Efforts
- Audience Q&A

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Antitrust Policy Notice

Linux Foundation meetings **involve participation by industry competitors**, and it is the intention of the Linux Foundation to conduct all of its activities in accordance with applicable antitrust and competition laws. It is therefore extremely important that attendees adhere to meeting agendas, and be aware of, and not participate in, any activities that are prohibited under applicable US state, federal or foreign antitrust and competition laws.

Examples of types of actions that are prohibited at Linux Foundation meetings and in connection with Linux Foundation activities are described in the Linux Foundation Antitrust Policy available at **http://www.linuxfoundation.org/antitrust-policy**. If you have questions about these matters, please contact your company counsel, or if you are a member of the Linux Foundation, feel free to contact Andrew Updegrove of the firm of Gesmer Updegrove LLP, which provides legal counsel to the Linux Foundation.

Code of Conduct

- The Linux Foundation and its project communities are **dedicated to providing a harassment-free experience** for participants at all of our events, whether they are held in person or virtually.

- All event participants, whether they are attending an in-person event or a virtual event, **are expected to behave in accordance with professional standards**, with both this Code of Conduct as well as their respective employer's policies governing appropriate workplace behavior and applicable laws.

- https://openssf.org/community/code-of-conduct/

Introductions

Nicole Bates - Principal Technical Program Manager, Microsoft

Nicole Bates works in Microsoft's Azure Office of the CTO where she focuses on supply chain security. She is actively involved in the OpenSSF's Supply Chain Integrity and ORBIT Working Groups and contributes to standards development through the IETF's Supply Chain Integrity, Transparency and Trust and COSE working groups. She is currently working on an AIBOM tool. Her experience spans over 20 years working in computer security at UC Berkeley, General Dynamics, and Microsoft. While at UC Berkeley's intrusion detection team, she specialized in computer forensics, analyzing compromised computers and investigating major threats including the Code Red and Nimda worms, building foundational expertise in threat detection and digital investigation that informs her current efforts in supply chain security.

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Roman Zhukov

Roman Zhukov is a cybersecurity expert, engineer, and leader with over 17 years of hands-on experience securing complex systems and software products at scale. At Red Hat, Roman leads open source security strategy, upstream collaboration, and cross-industry initiatives focused on building trusted ecosystems. He is an active contributor to open source security and co-chair of the OpenSSF Global Cyber Policy WG.

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Eddie Knight - OSPO Lead, Sonatype

Eddie Knight is a Software and Cloud Engineer with a background in banking technology. When he isn’t playing with his 3-year-old son, he combines his passion and job duties by working to improve the security of the open source software ecosystem.

Eddie helps lead interconnected efforts on CNCF's Security Technical Advisory Group, the FINOS Technical Oversight Committee, the Common Cloud Controls project, the Gemara project, and the OpenSSF's Security Baseline.

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Sarah Evans - Distinguished Engineer, Dell

Sarah Evans delivers technical innovation for secure business outcomes through her role as the security research program lead and Distinguished Engineer in the Office of the CTO at Dell Technologies. She is an industry leader and advocate for extending secure operations and supply chain development principles to AI. Sarah also ensures the security research program explores the overlapping security impacts of emerging technologies in other research programs, such as quantum computing. Sarah leverages her extensive practical experience in security and IT, spanning small businesses, large enterprises (including the highly regulated financial services industry and a 21-year military career), and academia (computer information systems). She earned an MBA, an AIML professional certificate from MIT, and is a certified information security manager (CISM). Sarah is also a strategic and technical leader representing Dell in OpenSSF, a foundation for securing open-source software.

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

The Origin Story

Why We're Here

01

CRA Enforcement Deadline

CRA deadlines begin in Sept 2026 for actively exploited vulnerability reporting with full compliance by Dec 2027.

02

Shift from Reactive to Proactive

CRA pushes organizations to move from reactive fixes to proactive, upstream-focused security.

03

Impact on upstream OSS and Suppliers

Upstream OSS projects and suppliers must strengthen security practices as CRA accountability shifts onto the entire supply chain.

EU CRA Drives Change

01

Mandatory vulnerability handling Requirements

CRA enforces strict, time-bound obligations for identifying and reporting actively exploited vulnerabilities.

02

Supply chain responsibility expands

Strict security accountability across the full supply chain, including all third-party and upstream components.

03

Manufacturers must ensure upstream security maturity

Manufacturers must verify that upstream OSS and suppliers follow secure development practices to meet CRA expectations.

Launchpad at a Glance

Introducing....ORBIT Launchpad!

What It Is

- Lower the learning curve to improve secure OSS consumption to prepare for CRA
- CRA OSS consumption guidance aligned with tools to meet the guidance.
- Bridge between Global Cyber Policy and ORBIT Working Groups

How It Operates

- Principles: *Do no harm, Transparency, No duplication, Meet developers where they are, Good is good enough.*
- Supports ORBIT projects without affecting their governance.
- Connects OSS security tool maintainers with end users.
- Integrate and sustain security tools

2026 Focus Areas

- Enable CRA readiness for OSS consumers.
- Align compliance guidance with Global Cyber Policy WG.
- Coordinate with ORBIT maintainers to strengthen upstream tooling.
- Integrate OpenSSF tools (Scorecard, Minder, Baseline, SLSA).

Key Outcomes

- CRA requirements mapping & readiness checklist.
- Tooling improvements and gap identification.
- Shared best practices and community guidance.

Objectives

1. **Align Manufacturer CRA Compliance Requirements:** Identify and document specific CRA compliance obligations that apply to the consumption of open source software for manufacturers.

2. **Partner to Drive ORBIT Tooling Improvements** Assess Baseline Catalog and extend to create a set of controls for CRA compliance for manufacturers. Evaluate existing tools as needed for CRA requirements not met by Baselines and implement improvements. Identify tooling gaps, create issues to address gaps enabling developer community engagement.

3. **Promote ORBIT Tooling Improvements:** Drive awareness for achieving and demonstrating secure compliance within the context of software supply chain security. Partner with Global Policy WG to develop CRA Security Compliance Tooling Guidance.

Perspective: Global Cyber Policy WG

Roman Zhukov
Open Source Leader, Red Hat

Global Cyber Policy (GCP) WG

- What we do
  - A forum for open source community to collaborate on Global Cybersecurity-related legislation, frameworks, and standards
  - Center of expertise for navigating global policies affect FOSS ecosystem
  - Guides, Checklist, Papers, Regular CRA Updates
  - The Free LF Training on CRA - 5.5k+ enrollments
  - CRA Workshops (Ghent and Brussels) & FOSDEM DevRoom
- Learn more and join GCP WG
  - https://github.com/ossf/wg-globalcyberpolicy/
  - Any questions - contact co-chairs Dan Appelquist & Roman Zhukov on OpenSSF Slack

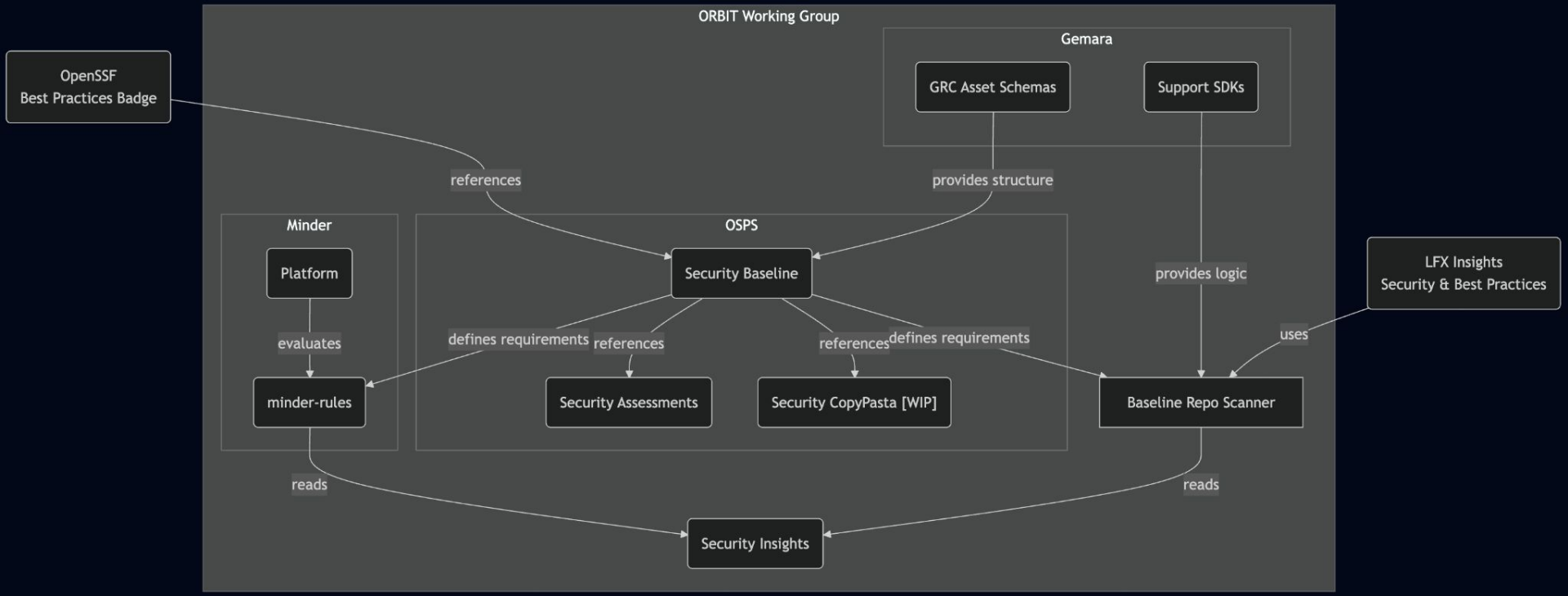
Why Launchpad is Essential Missing Piece

- Maintainers and contributors have no obligations under CRA if they don't monetize FOSS (90%+ of projects)
- But manufacturers (FOSS consumers) do
  - ...
  - **Due Diligence for 3rd party components (including FOSS)**
  - ...
- Suddenly, manufacturers **have to** assess FOSS to continue adopting and using them
  - Standardized and scalable way without bothering maintainers
- FOSS projects **may want to** demonstrate they follow good security practices in alignment with CRA
  - Easiest way possible with minimal friction -> Concise Framework, Tools, Automation, Dev-Centric
- GCP WG is looking forward to close collaboration with Launchpad and can't wait to start piloting it across FOSS projects and manufacturers

Perspective: ORBIT WG

Eddie Knight
OSPO Lead, Sonatype

Open Resources for Baselines and Interoperable Tooling



ORBIT Technical Steering Committee (2025)

Technical Initiative	Lead
Open Source Project Security Baseline	Ben Cotton (@funnelfiasco)
Open Source Project Security Assessments	John Kjell (@jkjell)
Security Insights Specification	Eddie Knight (@eddie-knight)
Gemara	Jennifer Power (@jpower432)
ORBIT Tooling	Travis Truman (@trumant)

Changed in 2026

Opportunities and Emerging Efforts

OpenSSF

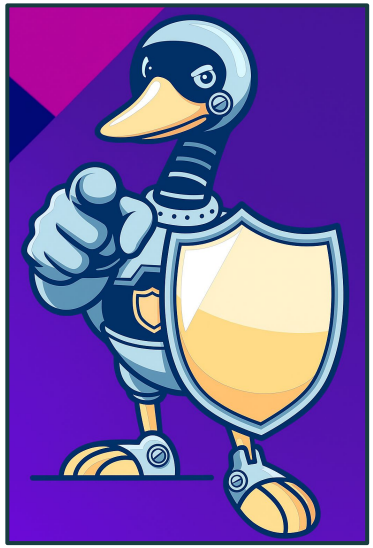
OPEN SOURCE SECURITY FOUNDATION

Potential Roadmap

Draft charter and Roadmap

- Collaborate with the Global Policy Working Group and members of the SIG to align on a common understanding of CRA compliance requirements.
  - Review and ensure Compliance Crosswalk Matrix captures CRA requirements, evidence/artifacts, and associated tooling to meet these requirements. Amend as needed.
- Drive awareness of industry best practices for achieving and demonstrating secure compliance within the context of software supply chain security. Partner with Global Policy WG to develop CRA Security Compliance Tooling Guidance: Contribute to Global Policy guidance, workflows, and templates (e.g., questionnaires, attestations) for software developers and consumers of open source software.
  - Develop standardized "Readiness Checklist" for onboarding or auditing upstream open source software. This includes identifying, aggregating and simplifying key security documentation and evidence required from open source projects that can be used for security open source consumption compliance.
- Assess current OpenSSF tools (like Scorecard, Minder, Best Practices badge site, and Pvtr) and suggest how they could be leveraged or modified to meet CRA requirements for upstream open source dependencies.

Get involved!



Github : https://github.com/ossf/orbit-launchpad

Meeting times :

Every other Friday at (March 6), 10:30 am MST; you can register for the community bi-weekly meetings with a calendar invite with this link.

But currently choosing a new time - complete this Doodle Poll

https://doodle.com/group-poll/participate/avxmW0md

Meeting minutes :
https://docs.google.com/document/d/1RTXX5TjPQjvlXvQFHHYq-Q5CnPWRrvRbeED603hPfk0/edit?tab=t.btmtfjk18wve#heading=h.sor2rsxqqeql

Panel Discussion & Audience Q&A

Thank You

OpenSSF
OPEN SOURCE SECURITY FOUNDATION

Legal Notice

Copyright © Open Source Security Foundation®, The Linux Foundation®, & their contributors. The Linux Foundation has registered trademarks and uses trademarks. All other trademarks are those of their respective owners.

Per the OpenSSF Charter, this presentation is released under the Creative Commons Attribution 4.0 International License (CC-BY-4.0), available at <https://creativecommons.org/licenses/by/4.0/>. You are free to:

- Share — copy and redistribute the material in any medium or format for any purpose, even commercially.
- Adapt — remix, transform, and build upon the material for any purpose, even commercially.

The licensor cannot revoke these freedoms as long as you follow the license terms:

- Attribution — You must give appropriate credit , provide a link to the license, and indicate if changes were made . You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- No additional restrictions — You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.